

임원 보고서

Linux 자산 가시성 확보를 위한 Agent v0.2.3·Server v0.2.5 도입
가치, 통제 경계와 단계별 확산 제안

대상 릴리즈 Agent v0.2.3 · Server v0.2.5

보고서 버전 1.0

기준일 2026-07-29

의사결정 등급 제한 운영 승인 검토

v0.2.3 중앙 자산 관리 확장 요약

이번 릴리즈는 Linux 수집 Agent를 중앙 자산 Intelligence 서비스로 확장합니다. PostgreSQL 기반 대표 자산, 원천 추적, 변경 이력, 관계, 안전한 Query DSL과 역할 기반 관리 콘솔을 제공합니다. PostgreSQL이 준비되지 않은 초기 도입은 SQLite로 시작할 수 있고, 운영 중 DB 장애에는 검증된 Agent 이벤트를 암호화 상태 영역의 내구성 spool에 보존합니다.

운영 단순화를 위해 모든 웹·API·Agent 통신을 TCP 7070 하나로 통합했고, Kubernetes 2개 이상 Pod에서 PostgreSQL migration과 세션을 공유하도록 개선했습니다. Agent는 Ed25519 서명, SHA-256, 단계적 rollout을 검증하는 자동 업데이트 체계를 제공하며 폐쇄망용 Server+PostgreSQL Docker image tar.gz도 함께 배포합니다.

신규 Agent 등록은 관리자가 DB 기반 정책으로 즉시 통제합니다. 신뢰된 내부망은 Server URL만 배포하는 Zero-touch 방식으로 운영하고, 경계가 넓은 망은 일회 표시 등록 Token 보호, 사고·동결 기간은 신규 등록 차단으로 전환할 수 있습니다. 정책은 모든 Kubernetes Pod에 동시에 적용되고 변경 이력은 감사 로그에 남습니다. 정확한 IP와 CIDR allowlist, 신뢰할 Ingress/프록시 대역을 별도로 관리해 전달 헤더 위조 없이 등록 경계를 자동 적용할 수 있습니다.

모든 Server Pod는 공용 PostgreSQL에 운영 진단 이벤트를 기록합니다. 관리자는 Pod, 수준, 오류 코드, Agent, IP와 request ID로 장애를 교차 추적하며, Agent 로그에 표시된 request ID로 Server 측 거부 원인을 바로 연결할 수 있습니다. 민감한 Token과 비밀번호는 저장 전에 마스킹하고 보존량을 제한합니다.

CMDB·자동화·AI 활용을 위해 자산 REST API와 읽기 전용 MCP 도구를 제공합니다. 연계별 API key는 최소 scope, 원문 비저장, scope 변경·삭제, 유예 회전과 즉시 폐기를 지원하므로 사람 계정이나 광범위한 공용 Token을 AI 시스템과 공유할 필요가 없습니다.

경영 관점의 통제 포인트는 세 가지입니다. 첫째, 무단 SQL이나 원격 명령 실행을 허용하지 않습니다. 둘째, 관리자 변경과 인증 사건을 감사 로그로 남깁니다. 셋째, 비밀번호와 Agent Token 원문을 데이터베이스나 화면에 재노출하지 않습니다. 따라서 단계적 PoC에서 중앙 PostgreSQL 운영으로 확장하면서도 자산 데이터의 출처와 변경 근거를 유지할 수 있습니다.

1. 의사결정 요약

Invenqor Agent v0.2.3는 Linux 서버의 운영체제, 하드웨어 자원, 네트워크, 프로세스, 설치 소프트웨어, 서비스, 계정과 컨테이너 환경을 비특권 방식으로 수집하는 경량 에이전트입니다. 외부 언어 런타임 없이 x86_64와 aarch64에서 실행되고, 중앙으로는 outbound HTTPS만 사용합니다.

권고: 전사 즉시 배포가 아니라 대표 배포판을 포함한 제한된 Pilot을 승인하고, 중앙 게이트웨이·접근통제·보존정책·운영 SLO가 검증된 뒤 단계적으로 확대하는 것이 적절합니다.

도입 판단의 핵심은 다음과 같습니다.

- **가치:** 수작업 자산조사의 지연을 줄이고, 자산 변경을 15분 기본 주기로 관찰할 수 있는 기반을 제공합니다.
- **안전성:** root나 inbound 포트를 요구하지 않으며, 전송 실패 중 데이터를 로컬 큐에 보존합니다.
- **현재 경계:** 중앙 수집 서버와 대시보드는 포함하지만 CVE 판정·정책 엔진·자동 시정은 별도 구축 또는 연계가 필요합니다.

- **통제 과제:** 자산정보의 분류·접근·보존, 인증서/토큰 수명주기, 배포 서명과 SBOM, 운영 모니터링을 조직 차원에서 보완해야 합니다.

운영 대시보드는 자산 최신성, Agent 건전성, 24시간 수집·실패, 7일 추이와 유형·환경·중요도·원천 분포를 공용 PostgreSQL 기준으로 제공합니다. 따라서 Kubernetes 멀티 Pod 환경에서도 임원·운영·감사 관점의 수치가 같은 기준으로 계산되며, 화면 임의 집계나 특정 Pod의 로컬 상태에 의존하지 않습니다.

2. 해결하려는 경영 문제

Linux 자산정보가 수작업 조사, 부서별 스크립트, 시점이 다른 CMDB 입력에 분산되면 다음 문제가 발생합니다.

1. **정확성 저하:** 실제 운영 상태와 자산대장의 차이가 누적됩니다.
2. **사고 대응 지연:** 특정 패키지·서비스·계정의 영향 범위를 즉시 산출하기 어렵습니다.
3. **감사 비용 증가:** 동일 증거를 여러 팀이 반복 수집하고 검증합니다.
4. **변경 통제 약화:** 무단 설치, 서비스 활성화, 네트워크 노출을 뒤늦게 발견합니다.
5. **레거시 사각지대:** 배포판과 init 시스템 차이로 단일 조사 방식이 실패합니다.

Invenqor Agent는 이 문제를 해결하기 위한 **신뢰 가능한 원천 데이터 수집층**입니다. 데이터를 경영·보안 의사결정으로 바꾸려면 중앙 정규화, 정책, 대시보드와 업무 프로세스가 추가로 필요합니다.

3. v0.2.3가 제공하는 범위

10개

기본 수집기 영역

2개

정적 바이너리 아키텍처

3개

지원 init 계열

15분

기본 전체 수집 주기

3.1 수집 범위

영역	경영·운영 활용
시스템/OS	배포판·커널 표준화, 지원 종료 대상 식별의 기초
CPU/메모리/파일시스템	용량 현황과 인프라 구성 파악
네트워크	인터페이스, IP, DNS, 기본 경로, 로컬 포트 가시성
프로세스/서비스	실행 구성과 변경 탐지의 기초

영역	경영·운영 활용
설치 패키지	소프트웨어 자산대장과 취약점 매핑의 입력
사용자 계정	로컬 계정 현황과 접근 검토의 입력
컨테이너 환경	런타임 존재와 실행 환경 식별

처음에는 전체 snapshot을 보내고 이후에는 추가·수정·삭제 변경만 전송합니다. 변경이 없어도 기본 5분 간격 heartbeat로 생존을 알립니다.

3.2 운영 복원력

- 한 수집기 실패가 전체 수집 실패로 확산되지 않도록 격리
- 수집 오류 시 누락을 삭제로 오판하지 않는 보수적 정책
- 게이트웨이 승인 전 이벤트를 삭제하지 않는 내구성 큐
- 전송 실패 시 1초부터 최대 1시간까지 지수 백오프
- 재시도 event ID 유지로 중앙 먹등 처리 가능

3.3 보안 설계

- 전용 비로그인 사용자, capability 없음
- systemd 파일시스템·권한·주소 패밀리 sandbox
- 운영 기본값은 HTTPS 전용이며 격리 테스트에서만 HTTP를 명시 허용
- 사설 CA, 장비별 mTLS PEM, bearer token 지원
- Agent inbound 포트, 원격 셸, 임의 명령 실행 없음
- 자동 업데이트는 Ed25519 서명·SHA-256·원자 교체·이전 바이너리 보존 적용
- 프로세스 명령행 기본 미수집
- 설정과 상태 파일의 제한된 권한

4. 가치 실현 구조

에이전트 배포

- 최신 Linux 자산 원천 데이터
- 중앙 정규화·중복 제거
 - CMDB / 취약점 관리 / 감사 증적
 - 노출 시간 단축·통제 자동화·의사결정 개선

에이전트만 설치한다고 최종 효과가 자동으로 발생하지 않습니다. 다음 조직 역량이 함께 있어야 합니다.

- 안정적인 HTTPS 게이트웨이와 agent/event 먹등 처리
- 자산 소유자, 서비스 중요도 등 업무 데이터와의 매핑

- CVE, 지원 종료, 정책 위반을 계산하는 중앙 분석
- 보안·운영·감사 사용자를 위한 역할 기반 접근
- 경보의 책임 팀과 처리 SLA
- 데이터 보존·파기와 개인정보 처리 기준

5. 정량 성과지표 제안

Pilot 전에 기준값을 측정하고, 목표값은 조직 규모와 현재 성숙도에 따라 승인합니다. 다음은 측정 프레임입니다.

관점	지표	Pilot 판단 기준 예시
커버리지	대상 Linux 중 heartbeat 정상 비율	95% 이상
최신성	마지막 성공 인벤토리 p95	30분 이내
신뢰성	24시간 event 전달 성공률	99% 이상
품질	수집기 오류 없는 호스트 비율	95% 이상
복구	네트워크 복구 후 backlog 해소 시간	합의 SLO 이내
보안	root/capability/inbound 예외	0건
운영	설치 1대당 수동 작업 시간	기존 대비 감소
데이터	CMDB 핵심 필드 일치율	표본 검증 목표 이상

효과 금액은 현재 인력 단가, 서버 수, 감사 빈도, 사고 조사 시간을 입력해 산출해야 합니다. v0.2.3 자료만으로 절감액이나 ROI를 단정하지 않습니다.

6. 위험과 통제 계획

6.1 주요 위험

위험	영향	v0.2.3 상태	필수 통제
중앙 시스템 장애	최신 데이터 지연	DB spool·자동 재처리	PostgreSQL HA·백업·SLO 운영
자산정보 과다 노출	공격 표면·개인정보 유출	계정/네트워크/프로세스 수집	분류, RBAC, 암호화, 조회 감사, 보존
명령행의 비밀정보	자격증명 유출	기본 비활성	승인 없는 활성화 금지
인증 비밀 유출	위조 agent 전송	token/mTLS 지원	장비별 발급, 제한 권한, 회전·폐기
Open 등록 경계 오설정	비인가 장비 등록	DB 정책과 IP/CIDR allowlist 적용	신뢰 프록시를 제한하고 외부는 Token 보호

위험	영향	v0.2.3 상태	필수 통제
큐 포화	신규 변경 event 생성 실패	기존 데이터 보존 후 실패	70/90% 경보, 게이트웨이 SLO
부분 수집 오류	실제 삭제 탐지 지연	삭제 보수 억제	오류율 경보와 운영 예외 처리
공급망 증적 부족	패키지 진위 검증 한계	SHA-256만 제공	조직 서명, SBOM/provenance 로드맵
자동 업데이트 오배포	서비스 중단·공급망 위험	Ed25519·SHA-256·단계적 rollout	승인 키 분리, canary, 이전 바이너리 복구 시험
플랫폼 편차	일부 필드 누락	점진적 기능 저하	대표 OS Pilot과 예외 기준

6.2 명확한 비기능 범위

다음 기능은 현재 릴리즈가 제공한다고 해석하면 안 됩니다.

- 취약점/CVE 식별과 위험도 계산
- 자산 소유자나 업무 중요도 자동 판정
- 원격 조치, 원격 셀, 스크립트 실행
- 장애 후 애플리케이션 상태를 판정하는 완전 자동 health-check rollback
- 컨테이너/Pod/이미지 전체 목록
- PostgreSQL 자체의 HA·백업·재해복구 자동 구성
- 모든 Linux 배포판과 커널에 대한 동일 수준 보장

7. 단계별 도입안

단계 0 — 통제 설계

목표: 배포 전에 데이터와 운영 책임을 확정합니다.

- 데이터 소유자, 처리 목적, 보존 기간, 접근 역할 승인
- 게이트웨이 API와 event idempotency 구현
- bearer token 또는 mTLS 표준 선택
- 호스트/중앙 모니터링과 사고 대응 절차 준비
- 체크섬, 내부 저장소, 배포 승인 체계 구성

진입 조건: 보안·인프라·개인정보·자산관리 책임자의 설계 승인.

단계 1 — 기술 Pilot

권장 범위: 20~50대, 운영 중요도가 낮고 배포판·아키텍처·init을 대표하는 호스트.

- 설치/제거/재부팅/업그레이드 시험
- 전체 수집 필드와 실제 호스트 정보 표본 대조

- 네트워크 단절, 잘못된 인증, 게이트웨이 장애 시험
- 큐 포화 전 경보와 복구 후 순차 전송 확인
- CPU, 메모리, 디스크, 네트워크 부하 측정

종료 조건: 승인된 성과지표 달성, 중대 보안 이슈 0건, 운영 런북 검증.

단계 2 — 제한 운영

권장 범위: 비핵심 업무군 10~20%.

- canary와 ring 기반 배포
- CMDB 매핑과 데이터 품질 리포트
- 경보 책임 팀과 처리 SLA 운영
- 인증서/token 회전 실전 검증
- 플랫폼 예외와 수집 제외 정책 확정

단계 3 — 전사 확대

- 핵심 업무는 별도 변경창과 rollback 준비 후 포함
- 월별 커버리지·최신성·오류·backlog 경영 지표
- 버전 노후화와 인증서 만료 통제
- SBOM, 서명, provenance와 중앙 DR 개선 로드맵 집행

8. 책임 체계 제안

업무	책임 (Accountable)	실행 (Responsible)	협업
제품 버전·보안 수정	제품 책임자	개발팀	보안팀
호스트 배포·서비스 운영	인프라 책임자	Linux 운영팀	업무 운영팀
게이트웨이·저장소	플랫폼 책임자	플랫폼팀	개발·보안
인증서/token 수명주기	보안 책임자	IAM/PKI팀	인프라팀
데이터 분류·보존	데이터 책임자	자산관리팀	법무·개인정보
취약점/정책 분석	CISO 조직	보안 운영팀	자산관리팀
사고 대응	운영 책임자	해당 장애 주관팀	제품·보안·플랫폼

실제 조직도에 맞춰 RACI를 승인 문서에 구체화해야 합니다.

9. 비용 항목

예산에는 바이너리 자체 외에 다음 항목을 포함해야 합니다.

- 게이트웨이 개발/운영과 고가용성
- 저장 용량, 백업, 보존·파기
- CMDB·취약점 시스템 연계
- 인증서 또는 token 발급·회전 자동화
- Linux 배포 자동화와 테스트 환경
- 모니터링, 당직, 장애 대응
- 데이터 접근 검토와 감사
- 공급망 통제(SBOM, 서명, provenance)

정확한 TCO는 Pilot에서 호스트당 이벤트 크기, 변경 빈도, 큐 증가율, 저장 보존 기간과 운영 투입시간을 측정한 뒤 산출합니다.

10. 릴리즈 품질 증적

Agent v0.2.3·Server v0.2.5 릴리즈 시 확인된 항목:

- Rust format 검사
- Clippy 경고 0 기준
- Rust 단위 테스트 23개, React 단위 테스트 14개와 전체 Go 테스트 통과
- x86_64/aarch64 musl 정적 빌드
- 두 아카이브 SHA-256 검증
- CentOS 7, Red Hat UBI 8/9, Ubuntu 22.04/24.04, Alpine 실제 E2E
- Server 2-Pod 공용 정책·자산·진단 로그 교차 조회 E2E
- IP/CIDR 등록 정책, trusted proxy 위조 방지와 즉시 자산 생성 검증
- Keycloak 최소 정보 Discovery·자동 설정과 메뉴 새로고침 상태 복원 검증
- 서명 업데이트 게시·인증 다운로드·검증·스테이징 E2E
- 오프라인 Docker image tar.gz 재적재·기동 검증
- GitHub Actions CI

이 증적은 소프트웨어 기본 품질을 지지하지만 침투 테스트, 독립 보안성 평가, 성능/용량 인증, 전 배포판 호환성 인증을 대체하지 않습니다.

11. 임원 승인 요청 항목

다음 항목을 승인하거나 담당 임원에게 배정해야 Pilot이 통제된 상태로 진행됩니다.

1. **Pilot 범위:** 20~50대 대표 Linux 호스트와 제외 대상
2. **데이터 책임자:** 수집 목적, 등급, 접근자, 보존·파기 승인 주체
3. **플랫폼 책임자:** 게이트웨이, 저장소, 고가용성, 먹등 처리 책임
4. **인증 표준:** 장비별 mTLS 우선 또는 장비별 token 사용 기준
5. **성과지표:** 커버리지, 최신성, 전달 성공률, 오류율, 운영 부하 목표
6. **확대 Gate:** Pilot 종료 후 보안·운영·데이터 품질 공동 승인
7. **보완 로드맵:** SBOM/서명/provenance, 자동화, 중앙 모니터링 투자
8. **Identity Governance:** Keycloak OIDC 연계, 역할/그룹 mapping 책임자, 로컬 비상 관리자와 정기 접근권한 검토 기준

12. 결론

Invenqor Agent v0.2.3는 Linux 자산 가시성의 가장 아래층인 **현장 수집과 신뢰성 있는 전달**에 집중한 초기 릴리즈입니다. 비특권·outbound-only·부분 실패 격리·내구성 큐라는 설계는 통제된 Pilot을 시작하기에 합리적입니다.

다만 제품의 가치는 중앙 게이트웨이, 자산 업무 데이터, 보안 분석과 운영 절차가 결합될 때 실현됩니다. 따라서 현재 의사결정은 “전사 표준 완성” 승인이 아니라, 측정 가능한 성공 기준과 보완 통제를 전제로 한 **제한 Pilot 승인**이어야 합니다.

상세 운영 기준: [관리자 가이드](#) · 현장 사용 절차: [사용자 가이드](#) · 프로젝트 저장소: [GitHub](#)